

Github Audit Report

Date: 2026-04-01

Audit Summary

Total Controls	5
Passed	2
Failed	3
Out of Scope	0

Control ID	Control Description	Results	Comments
C1000	The Github organization settings require users to enable MFA.	Pass	
C2000	Code repositories are configured to require an approval before the change is merged.	Fail	
C2010	All sensitive repositories are private or restricted.	Pass	
C2020	Code changes are approved by a separate user before they are deployed to production.	Fail	
C2030	The Github organization is configured to prevents members from creating public resources.	Fail	

Control ID	C1000
Control Description	The Github organization settings require users to enable MFA.
Conclusion	Pass
Test Procedures	1. Retrieved the Github organization settings by calling: https://api.github.com/orgs/itauditguy-training. 2. Inspected 'org_settings.json' in the evidence folder to determine it is compliant with the test attributes below.
Test Attributes	• 'two_factor_requirement_enabled' in org_settings.json is set to true.

Control ID	C2000
Control Description	Code repositories are configured to require an approval before the change is merged.
Conclusion	Fail
Test Procedures	1. Retrieved a list of all repositories in the Github organization. 2. Worked with the engineering team to determine which repositories were in-scope for the audit. 3. For each in-scope repository, retrieved the branch protection rules and rulesets. 4. Inspected all in-scope repositories to determine if they were compliant with the test attributes below.
Test Attributes	• An active ruleset OR branch protection rule is in enforced on the repository. • Pull requests merging into the 'main' branch require at least one approval.

Repository Name	Conclusion	Comments
training	Excluded	Sample excluded per config.json
bp-bypass	Pass	
ruleset-bypass	Fail	Branch protection exists but does not require PR approval
ruleset-no-bypass	Fail	No branch protection rules or rulesets configured
bp-no-bypass	Pass	

Control ID	C2010
Control Description	All sensitive repositories are private or restricted.
Conclusion	Pass
Test Procedures	1. Retrieved a list of all repositories in the organization/account. 2. Checked repository visibility against the audit config to ensure sensitive repos are not public.
Test Attributes	• No sensitive or classified repositories are public. • Public repositories comply with the organization's data classification policy.

Repository Name	Conclusion	Comments
training	Pass	
bp-bypass	Pass	
ruleset-bypass	Pass	
ruleset-no-bypass	Pass	
bp-no-bypass	Pass	

Control ID	C2020
Control Description	Code changes are approved by a separate user before they are deployed to production.
Conclusion	Fail
Test Procedures	1. Retrieved a list of all repositories in the Github organization. 2. Worked with the engineering team to determine which repositories were in-scope for the audit. 3. For each in-scope repository, retrieved a list of merged pull requests. 4. Randomly sampled 5 PRs from each in-scope repo and tested for the attributes below.
Test Attributes	• The pull request was approved before it was merged to the main branch. • The pull request was opened and approved by separate users.

Sample Number	Repository Name	PR Number	Conclusion	Comments
1	training	1	Fail	No valid approvals before merge
2	training	2	Pass	
3	training	3	Pass	
4	training	4	Fail	No valid approvals before merge

Control ID	C2030
Control Description	The Github organization is configured to prevents members from creating public resources.
Conclusion	Fail
Test Procedures	1. Retrieved the Github organization settings by calling: https://api.github.com/orgs/itauditguy-training. 2. Inspected 'org_settings.json' in the evidence folder to determine it is compliant with the test attributes below.
Test Attributes	• 'members_can_create_public_repositories' in org_settings.json is set to false. • 'members_can_create_public_pages' in org_settings.json is set to false.